Travaux pratiques – Interpréter les données HTTP et DNS pour isoler un hacker

Objectifs

Au cours de ces travaux pratiques, vous allez consulter les journaux collectés lors de l'exploitation de vulnérabilités HTTP et DNS documentées.

Partie 1: Enquêter sur une attaque par injection de code SQL

Partie 2: Enquêter l'exfiltration des données DNS

Contexte/scénario

MySQL est une base de données populaire utilisée par de nombreuses applications web Malheureusement, l'injection de code SQL est une technique de cyberattaque relativement répandue. En injectant du code SQL, le hacker exécute des instructions SQL malveillantes pour tenter de contrôler le serveur de base de données d'une application web.

Les serveurs de noms de domaine (DNS) sont des répertoires de noms de domaine qu'ils traduisent en adresses IP. Ce service peut être utilisé pour exfiltrer des données.

Le personnel de la cybersécurité a déterminé qu'un exploit s'est produit et que les données contenant des PII ont pu être exposées à des acteurs de menace. Dans ce TP, vous allez utiliser Kibana pour enquêter sur les exploits afin de déterminer les données qui ont été exfiltrées à l'aide de HTTP et de DNS pendant les attaques.

Ressources requises

- La machine virtuelle Security Onion

Instructions

Partie 1 : Enquêter sur une attaque par injection de code SQL

Dans cette partie, vous examinerez un exploit dans lequel un accès non autorisé a été effectué à des informations sensibles stockées sur un serveur Web. Vous utiliserez Kibana pour déterminer la source de l'attaque et les informations auxquelles l'attaquant a accédé.

© 2018 - aa Cisco et/ou ses filiales. Tous droits réservés. Document public de Cisco

Étape 1: Modifiez le délai.

Il a été déterminé que l'exploit s'est produit à un moment donné au cours du mois de juin 2020. Kibana affiche par défaut les données des dernières 24 heures. Vous devrez modifier les paramètres d'heure pour afficher les données du mois de juin 2020.

a. Ouvrez une session sur la machine virtuelle Security Onion avec le nom d'utilisateur **analyst** et le mot de passe **cyberops**.

b. Saisissiez la commande **sudo so-status** pour vérifier l'état des services. L'état de tous les services doit être **OK** avant de commencer votre analyse. Cela peut prendre quelques minutes.

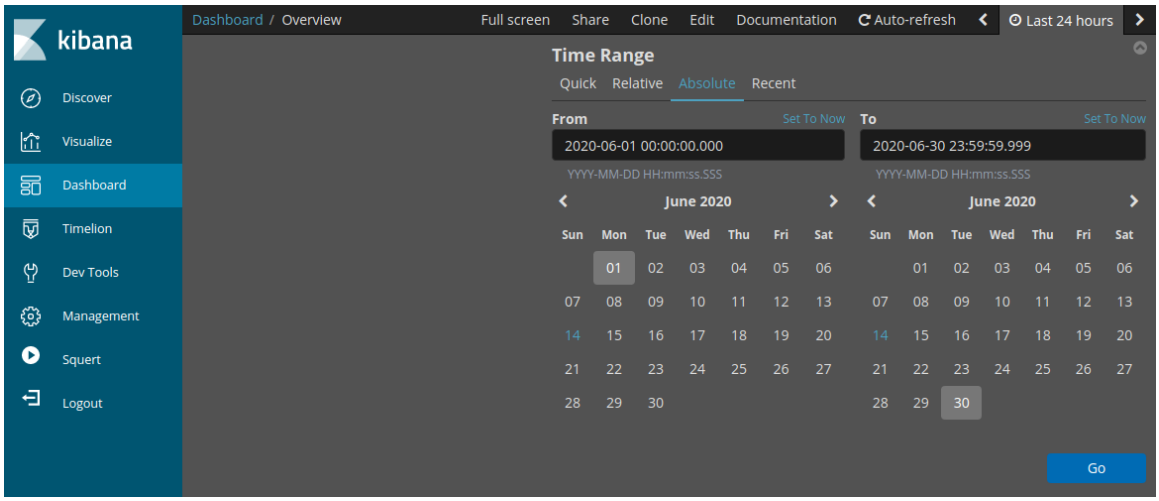
```
analyst@SecOnion:~$ sudo so-status
Status: securityonion
  * sguil server [ OK ]
Status: seconion-import
  * pcap_agent (sguil) [ OK ]
  * snort_agent-1 (sguil) [ OK ]
  * barnyard2-1 (spooler, unified2 format) [ OK ]
Status: Elastic stack
  * so-elasticsearch [OK]
  * so-logstash [OK]
  * so-kibana [OK]
  * so-freqserver [OK]
```

c. Après vous être connecté, ouvrez Kibana à l'aide du raccourci sur le Bureau. Connectez-vous avec le nom d'utilisateur **analyst** et le mot de passe **cyberops**.

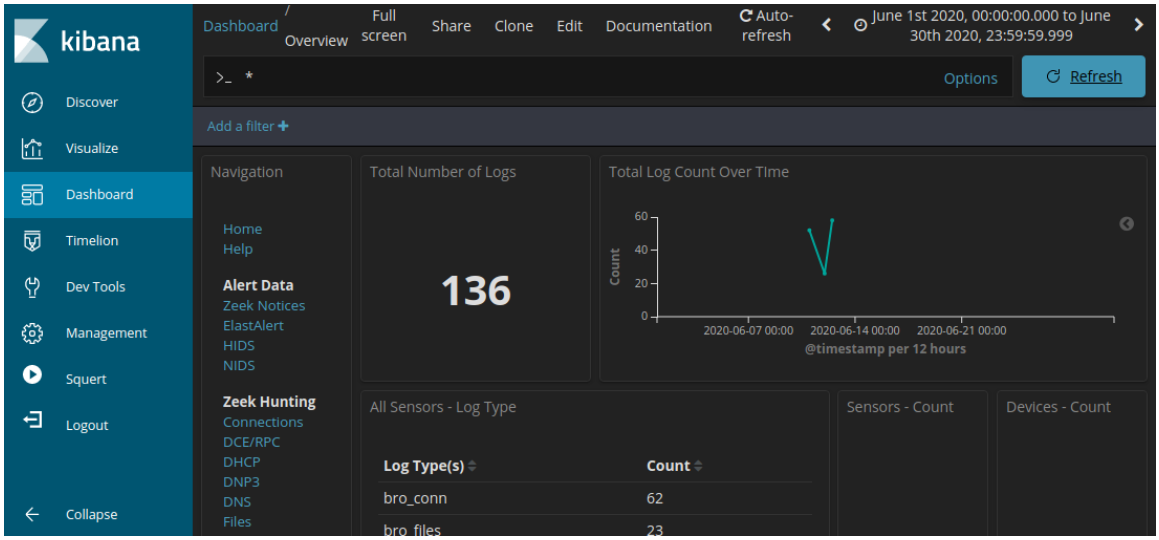
Dans Security Onion, Kibana dispose de nombreux tableaux de bord et visualisations prédéfinis pour la surveillance et l'analyse. Vous pouvez également créer vos propres tableaux de bord et visualisations personnalisés adaptés à la surveillance de votre environnement réseau particulier. **Remarque**: Votre tableau de bord n'ait pas de résultats au cours des dernières 24 heures.

© 2018 - aa Cisco et/ou ses filiales. Tous droits réservés. Document public de Cisco

d. Dans le coin supérieur droit de la fenêtre, cliquez sur **Dernières 24 heures** pour modifier la taille de la plage de temps de l'échantillon. Développez la plage de temps pour inclure les alertes intéressantes. Une attaque par injection SQL a eu lieu en juin 2020, c'est donc ce que vous devez cibler. Sélectionnez **Absolu** sous Plage de temps et modifiez les heures **De** et **À** pour inclure tout le mois de juin en 2020. Cliquez sur **Go** pour continuer.

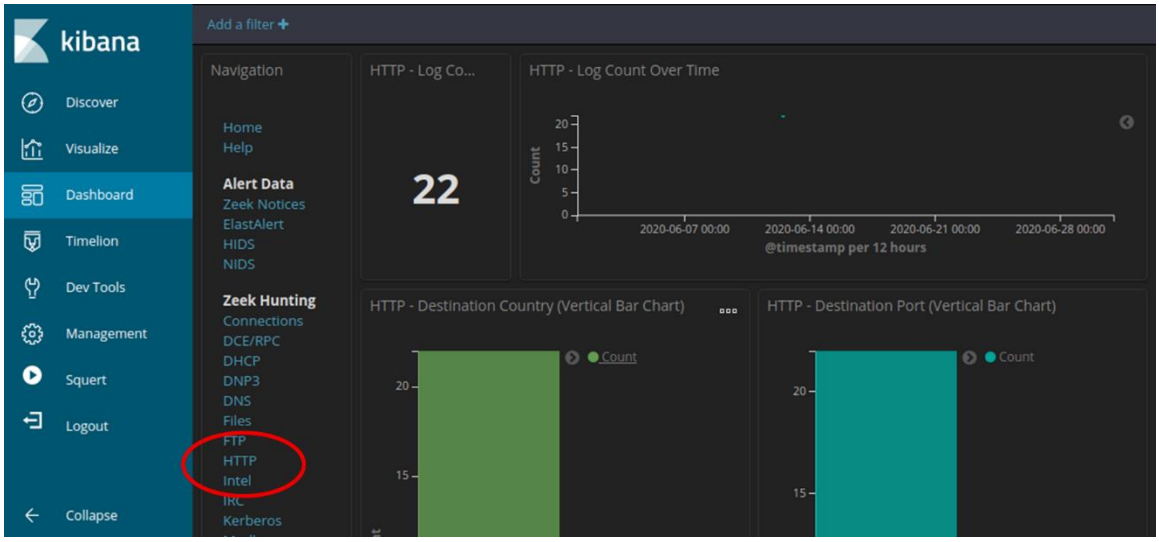


e. Notez le nombre total de journaux pour tout le mois de juin 2020. Votre tableau de bord doit être similaire à celui illustré dans la figure. Prenez un moment pour explorer les informations fournies par l'interface Kibana.



Étape 2: Filtrer le trafic HTTP.

a. Étant donné que l'acteur de menace a évalué les données stockées sur un serveur Web, le filtre HTTP est utilisé pour sélectionner les journaux associés au trafic HTTP. Sélectionnez HTTP sous l'en-tête de chasse Zeek, comme indiqué sur la figure.



Faites défiler les résultats et répondez aux questions suivantes:

Quelle est l'adresse IP source ?

Quelle est l'adresse IP de destination ?

Quel est le numéro du port de destination?

b. Faites défiler le contenu jusqu'à la section HTTP. Les résultats répertorient les 10 premiers résultats.

c. Développez les détails du premier résultat en cliquant sur la flèche située en regard de l'horodatage d'entrée de journal. Notez les informations disponibles.

Quel est l'horodatage du premier résultat?

Quel est le type d'événement?

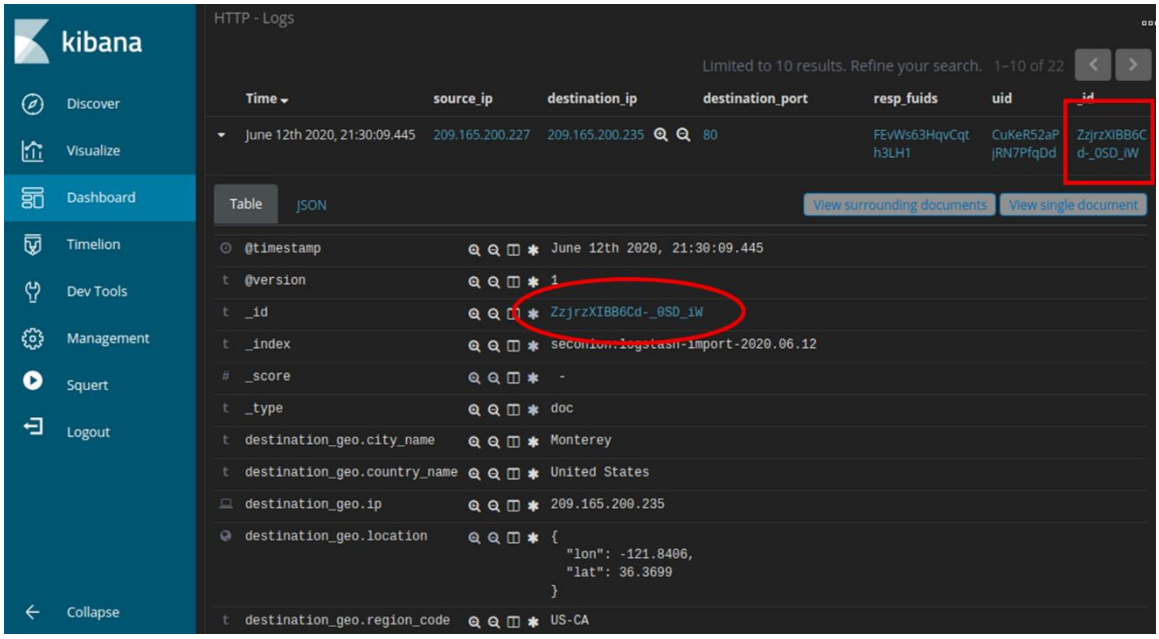
Qu'est-ce qui est inclus dans le champ de message? Ce sont des détails sur la requête HTTP GET qui a été effectuée par le client au serveur. Concentrez-vous en particulier sur le champ **uri** dans le texte du message.

Quelle est la signification de ces informations ?

© 2018 - aa Cisco et/ou ses filiales. Tous droits réservés. Document public de Cisco

Étape 3: Passez les résultats en revue.

a. Certaines informations relatives aux entrées de journal sont liées à d'autres outils. Cliquez sur la valeur dans le champ **_id** d'alerte de l'entrée de journal pour obtenir une vue différente de l'événement.

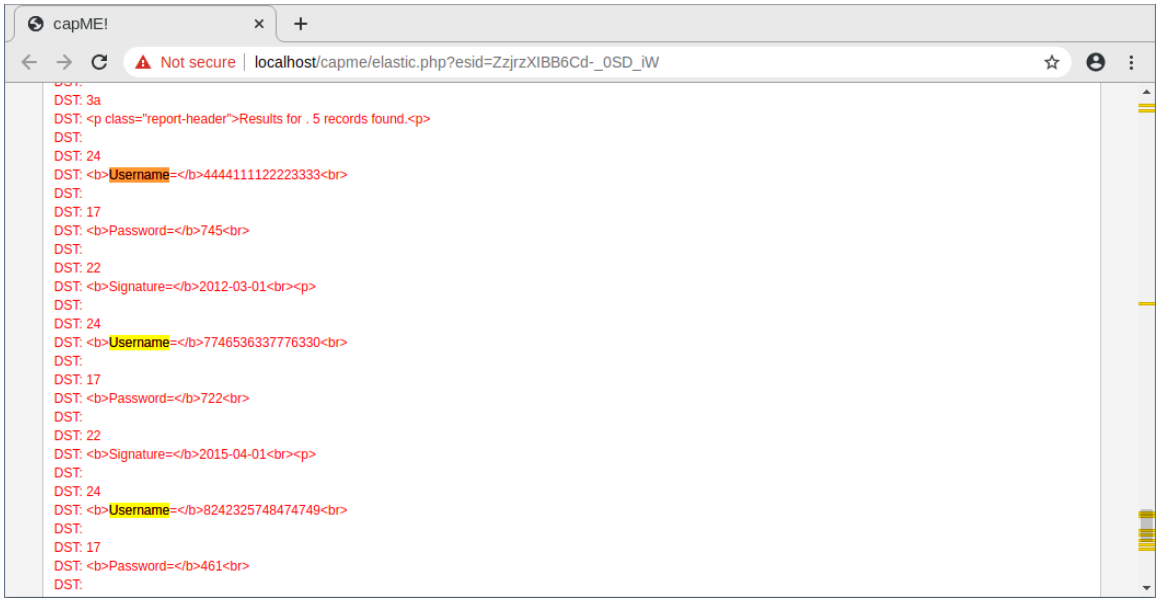


b. Le résultat s'ouvre dans un nouvel onglet de navigateur Web contenant des informations de capMe!. capMe! est une interface Web qui vous permet d'afficher une transcription pcap. Le texte bleu contient des requêtes HTTP envoyées à partir de la source (SRC). Le texte rouge est les réponses du serveur Web de destination (DST).

c. Dans la section d'entrée de journal, qui se trouve au début de la transcription, notez que la partie **username='+union+select+ccid, ccnumber, ccv, expiration, null+de+credit_cards+—+&password=** indique que quelqu'un a peut-être essayé d'attaquer le navigateur Web en utilisant l'injection SQL pour contourner l'authentification. Les mots-clés, **union** et **select**, sont des commandes utilisées pour rechercher des informations dans une base de données SQL. Si les zones de saisie d'une page Web ne sont pas correctement protégées contre les entrées illégales, les acteurs de menace peuvent injecter des chaînes de recherche SQL ou tout autre code pouvant accéder aux données contenues dans les bases de données liées à la page Web.

© 2018 - aa Cisco et/ou ses filiales. Tous droits réservés. Document public de Cisco

d. Recherchez le nom d'utilisateur du **mot** clé dans la transcription. Utilisez **Ctrl-F** pour ouvrir une zone de recherche. Utilisez la flèche vers le bas dans la zone de recherche pour faire défiler les occurrences trouvées.



Vous pouvez voir où le terme nom d'utilisateur a été utilisé dans l'interface Web affichée à l'utilisateur. Cependant, si vous regardez plus loin, quelque chose d'inhabituel peut être trouvé.

Que voyez-vous plus loin dans la transcription en ce qui concerne les noms d'utilisateur?

Donnez quelques exemples d'un nom d'utilisateur, d'un mot de passe et d'une signature qui a été exfiltré.

e. Fermez le CapME! et revenez à Kibana.

Partie 2 : Analyser l'exfiltration DNS.

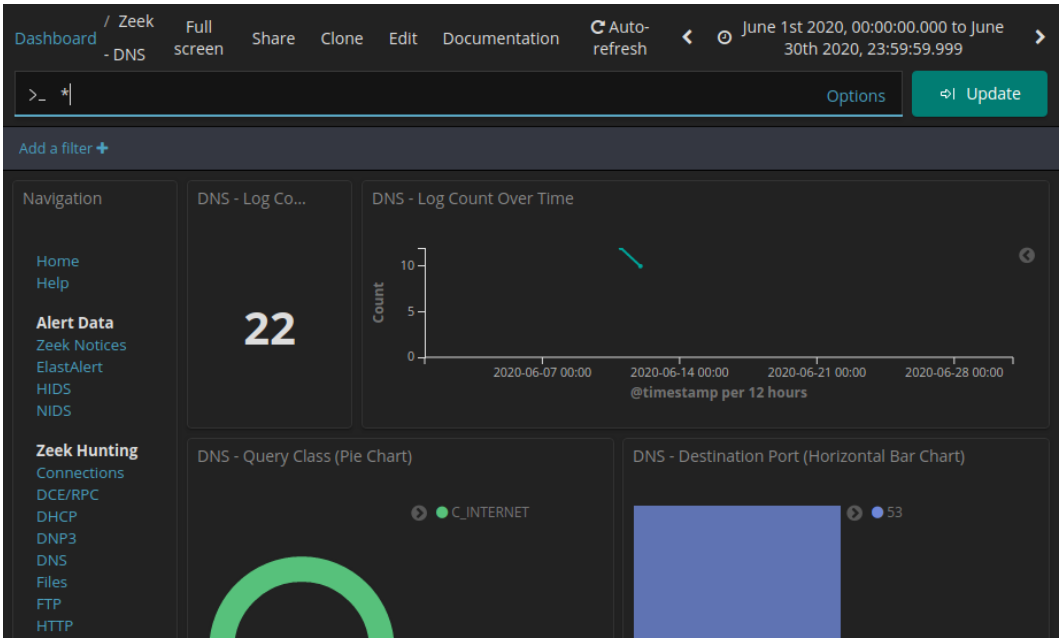
Un administrateur réseau a remarqué des requêtes DNS anormalement longues avec des sous-domaines d'apparence étrange. Votre travail est d'enquêter sur l'anomalie.

Étape 1: Filtre pour le trafic DNS.

a. En haut du Tableau de bord Kibana, effacez les filtres et les termes de recherche et cliquez sur **Accueil** dans la section Navigation du Tableau de bord. La période devrait toujours inclure juin 2020.

© 2018 - aa Cisco et/ou ses filiales. Tous droits réservés. Document public de Cisco

b. Dans la même zone du tableau de bord, cliquez sur **DNS** dans la section Zeek Hunting. Notez les mesures du nombre de journaux DNS et le graphique à barres horizontales Port de destination.

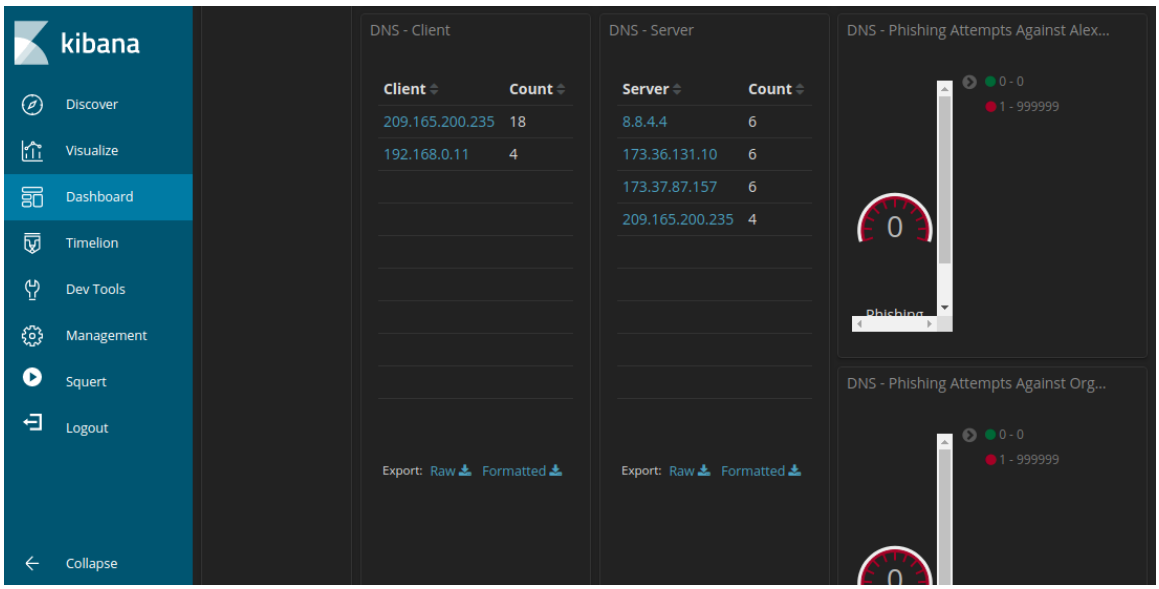


Étape 2: Passez en revue les entrées liées au DNS.

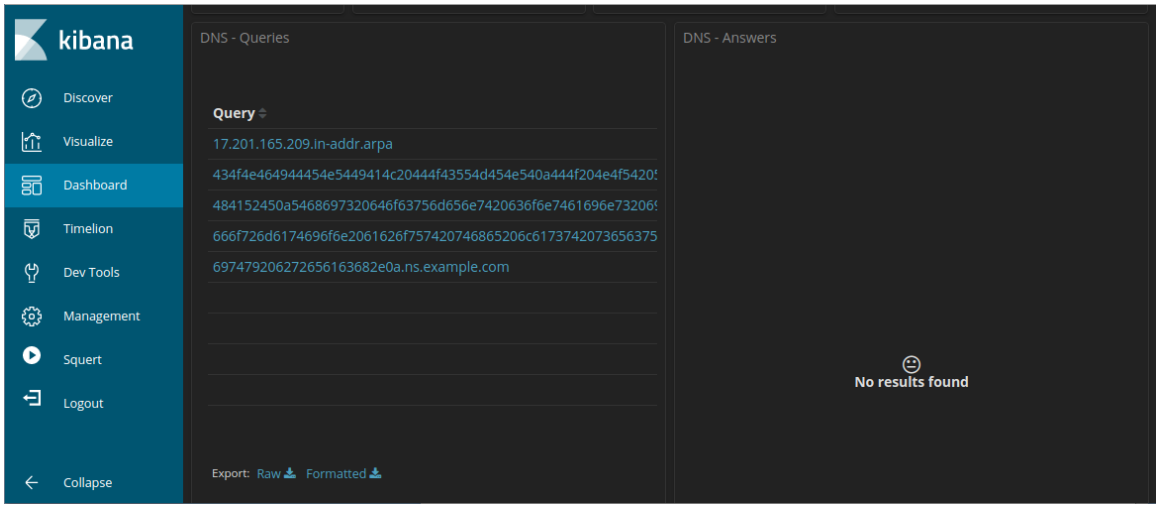
a. Faites défiler la fenêtre vers le bas. Vous pouvez voir les principaux types de requête DNS. Vous pouvez voir des enregistrements d'adresse (enregistrement A), des enregistrements Quad A d'adresse IPv6 (AAAA), des enregistrements NetBIOS (NB) et un enregistrement de pointeur pour résoudre les noms d'hôte (PTR). Vous pouvez également voir les codes de réponse DNS.

© 2018 - aa Cisco et/ou ses filiales. Tous droits réservés. Document public de Cisco

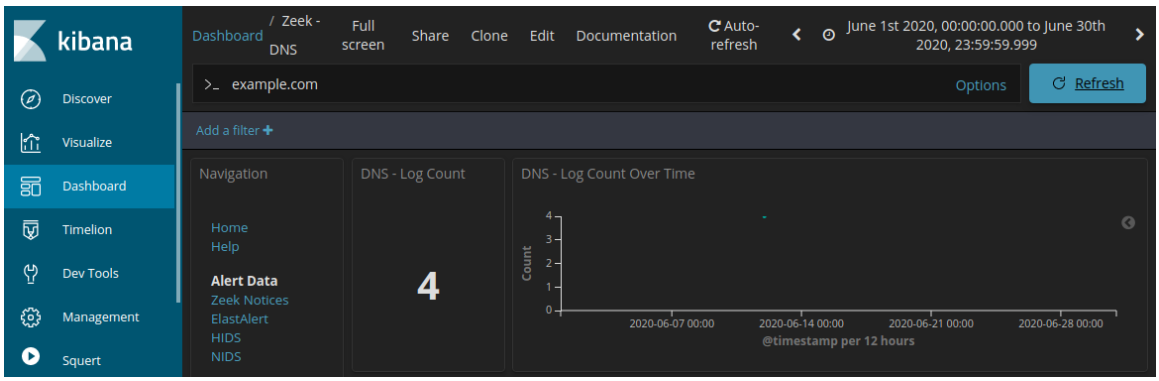
b. En faisant défiler plus loin vers le bas, vous pouvez voir une liste des principaux clients DNS et serveurs DNS en fonction de leur nombre de demandes et de réponses. Il existe également une mesure pour le nombre de tentatives d'hameçonnage DNS, qui sont également appelés DNS pharming, usurpation ou empoisonnement.



c. En défilant plus loin dans la fenêtre, vous pouvez voir une liste des principales requêtes DNS par nom de domaine. Notez que certaines des requêtes ont des sous-domaines exceptionnellement longs attachés à ns.example.com. Le domaine example.com doit faire l'objet d'une étude plus approfondie.



d. Faites défiler la page vers le haut de la fenêtre et entrez **example.com** dans la barre de recherche pour filtrer exemple.com et cliquez sur **Mettre à jour**. Notez que le nombre d'entrées dans le nombre de journaux est plus petit, car l'affichage est désormais limité aux demandes adressées au serveur example.com.



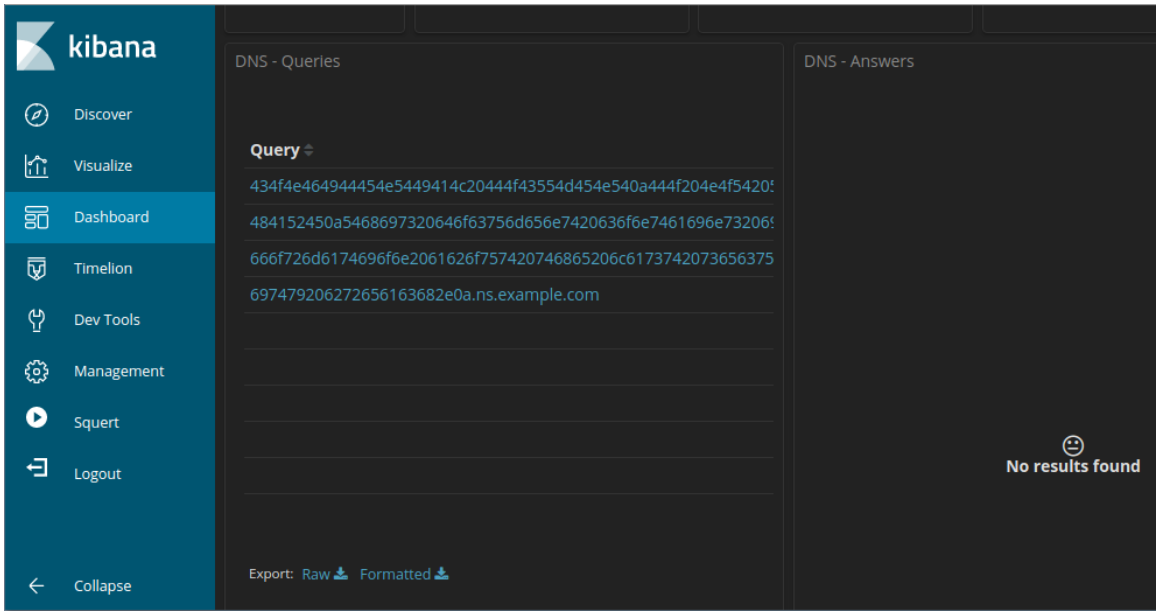
e. Recherchez des informations sur le DNS - Client et DNS - Serveur.

Enregistrez les adresses IP du client et du serveur DNS.

© 2018 - aa Cisco et/ou ses filiales. Tous droits réservés. Document public de Cisco

Étape 3: Déterminez les données exfiltrées.

a. Continuez à faire défiler plus loin vers le bas pour voir quatre entrées de journal uniques pour les requêtes DNS sur example.com. Notez comment les requêtes sont pour des sous-domaines de longueur suspecte attachés à ns.example.com. Les longues chaînes de chiffres et de lettres dans les sous-domaines ressemblent à du texte codé en hexadécimal (0-9, a-f) plutôt que des noms de sous-domaines légitimes. Cliquez sur le lien de téléchargement **Exporter: Raw** pour télécharger les requêtes dans un fichier externe. Un fichier CSV est téléchargé dans le dossier /HOME/analyst/Downloads.



b. Accédez au dossier **/home/analyst/downloads**. Ouvrez le fichier dans un éditeur de texte, tel que gedit. Modifiez le fichier en supprimant le texte entourant la partie hexadécimale des sous-domaines, en ne laissant que les caractères hexadécimaux. Veillez également à supprimer les guillemets. Le contenu de votre fichier doit ressembler aux informations ci-dessous. Enregistrez le fichier texte modifié avec le nom du fichier d'origine.

```
434f4e464944454e5449414c20444f43554d454e540a444f204e4f542053
484152450a5468697320646f63756d656e7420636f6e7461696e7320696e
666f726d6174696f6e2061626f757420746865206c617374207365637572
697479206272656163682e0a
```

c. Dans un terminal, utilisez la commande **xxd** pour décoder le texte dans le fichier CSV et l'enregistrer dans un fichier nommé secret.txt. Utilisez **cat** pour afficher le contenu de secret.txt sur la console.

```
analyst@SecOnion:~/Downloads$ xxd -r -p "DNS - Queries.csv" > secret.txt
analyst@SecOnion:~/$ cat secret.txt
```

Les sous-domaines des requêtes DNS étaient-ils des sous-domaines? Si ce n'est pas le cas, quel est le texte?

Qu'est-ce que ce résultat implique sur ces requêtes DNS particulières? Quelle est la plus grande importance?

Qu'est-ce qui a pu créer ces requêtes DNS encodées et pourquoi le DNS a-t-il été sélectionné comme moyen d'exfiltrer les données?

© 2018 - aa Cisco et/ou ses filiales. Tous droits réservés. Document public de Cisco